

RECONNAISSANCE

Finding hidden folders and files using gobuster tool

1. Checking if I have gobuster

```
(kali㉿kali)-[~]  
$ which gobuster  
/usr/bin/gobuster
```

2. Wordlists below

```
$ ls /usr/share/wordlists/dirb  
big.txt      euskera.txt      mutations_common.txt  spanish.txt  
catala.txt   extensions_common.txt  others                stress  
common.txt   indexes.txt      small.txt             vulns
```

3. Using the tool

```
(kali㉿kali)-[~]  
$ gobuster dir -u http://testphp.vulnweb.com -w /usr/share/wordlists/dirb/c  
ommon.txt
```

- Telling the tool that I want to look for directories and files ,hence I used dir
- Pointing the tool at a specific website
- Gobuster is going to take the names from the common.txt file and then it's going to add it to the website and it's going to see if that folder or file exist

```
(kali㉿kali)-[~]  
$ gobuster dir -u http://testphp.vulnweb.com -w /usr/share/wordlists/dirb/c  
ommon.txt  
=====
```

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
```

[+] Url:	http://testphp.vulnweb.com
[+] Method:	GET
[+] Threads:	10
[+] Wordlist:	/usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:	404
[+] User Agent:	gobuster/3.8.2
[+] Timeout:	10s

```
=====
```

Starting gobuster in directory enumeration mode

```
=====
```

admin	(Status: 301) [Size: 169] [→ http://testphp.vulnweb.co
m/admin/	
cgi-bin	(Status: 403) [Size: 276]
cgi-bin/	(Status: 403) [Size: 276]
crossdomain.xml	(Status: 200) [Size: 224]
CVS	(Status: 301) [Size: 169] [→ http://testphp.vulnweb.co
m/CVS/	
CVS/Repository	(Status: 200) [Size: 8]
CVS/Entries	(Status: 200) [Size: 1]
CVS/Root	(Status: 200) [Size: 1]
favicon.ico	(Status: 200) [Size: 894]
images	(Status: 301) [Size: 169] [→ http://testphp.vulnweb.co
m/images/	
index.php	(Status: 200) [Size: 4958]

4. RESULT

- Discovered a hidden directory called `CVS/Entries` that returned a Status 200.
- Manually verified this finding by navigating to the URL in a browser as shown in the screenshot, the server allowed me to download the internal system file.
- The file exposes names of files not intended for public view

